RAPPORT DE TP 4.2 : IDS/IPS SURICATA

Mise en place d'un système de détection et de prévention d'intrusions sur pfSense

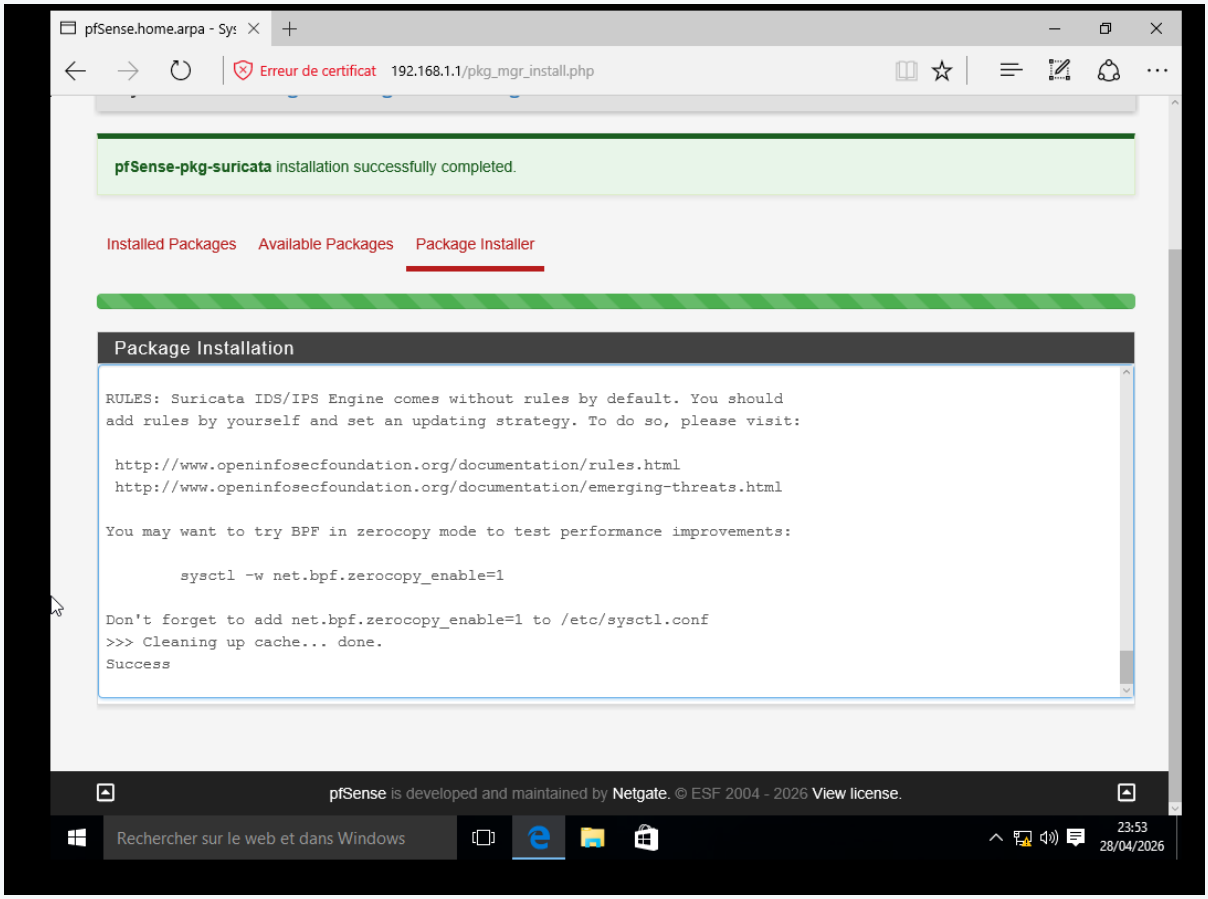
INTRODUCTION

Ce rapport détaille la mise en œuvre de **Suricata**, un IDS/IPS open-source, au sein d'une architecture réseau contrôlée par pfSense. L'objectif est d'ajouter une couche d'intelligence capable d'analyser le contenu du trafic en temps réel pour identifier des comportements malveillants.

2. Installation et Configuration

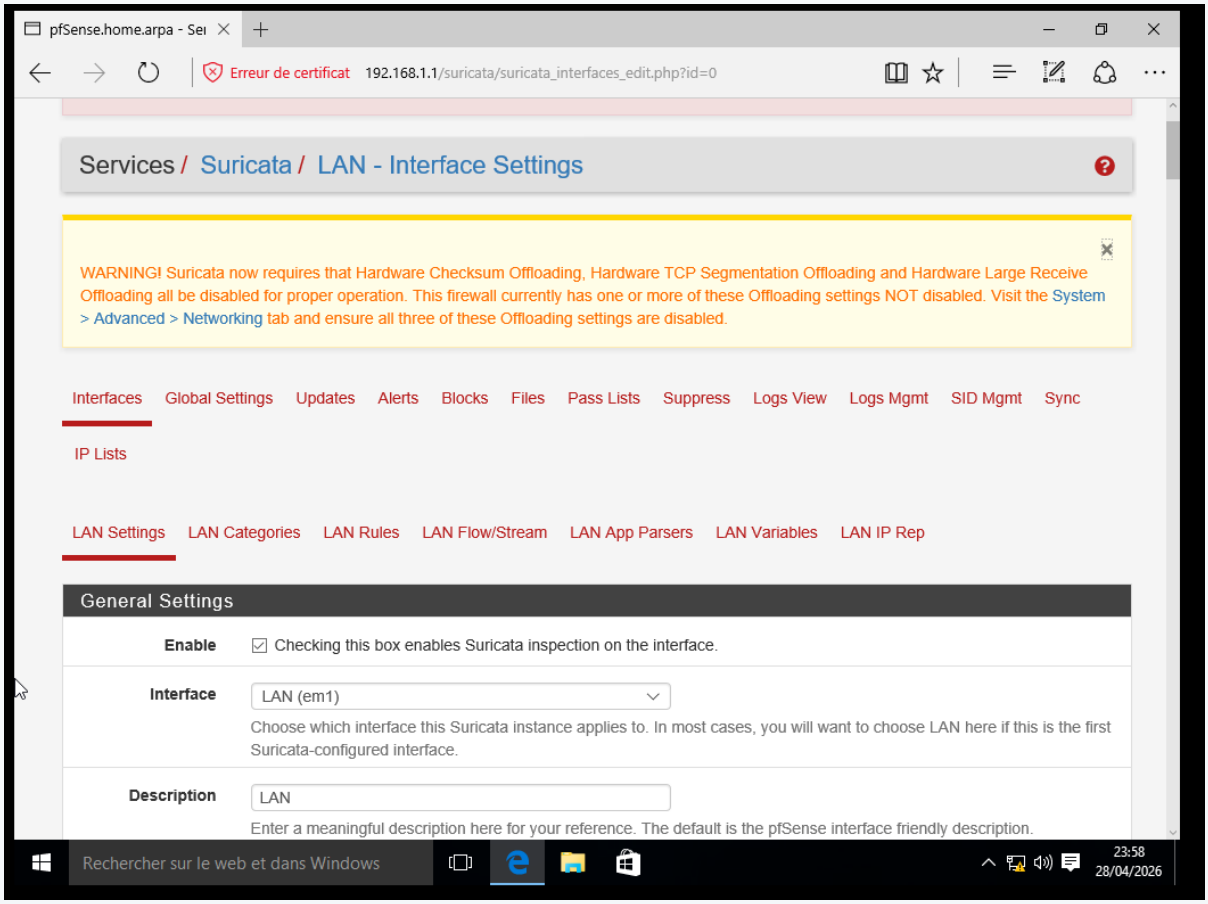
2.1. Installation de Suricata

L'installation a été réalisée via le *Package Manager* de pfSense. Cette étape permet d'étendre les capacités du pare-feu avec une analyse protocolaire approfondie.



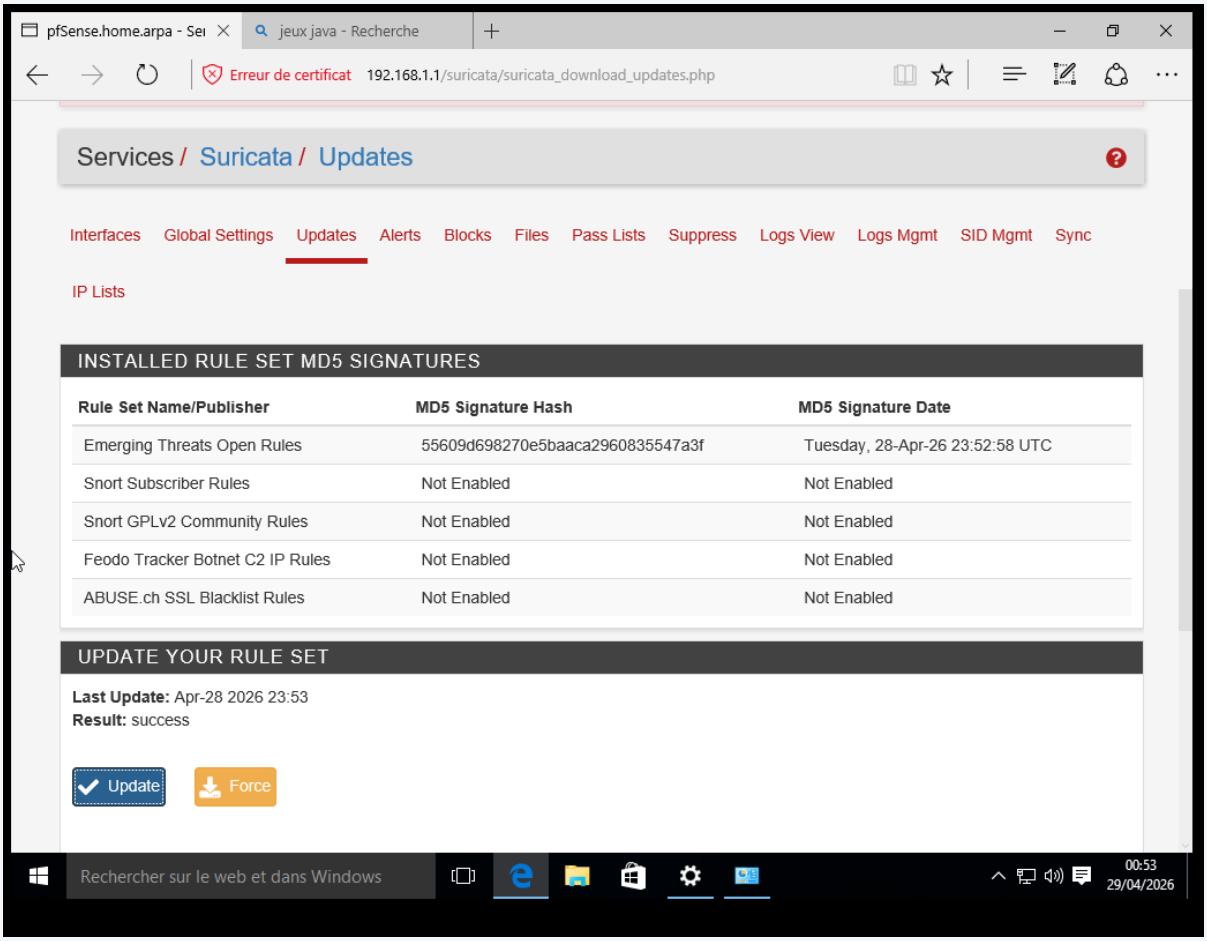
2.2. Activation sur l'interface LAN

Suricata a été activé sur l'interface LAN car la majorité des attaques modernes se produisent à l'intérieur du périmètre après une compromission initiale.



2.3. Gestion des règles et signatures

Nous avons activé les règles *ET Open (Emerging Threats)*. Ces signatures permettent à Suricata de reconnaître automatiquement des motifs d'attaques connus (scans, exploits, brute-force).



3. Tests d'attaques et Détection

3.1. Scan Nmap (Reconnaissance)

Une attaque par scan furtif (`nmap -sS`) a été lancée depuis la machine Kali.

Suricata a immédiatement identifié cette activité comme suspecte.

ntoguem@kali: ~

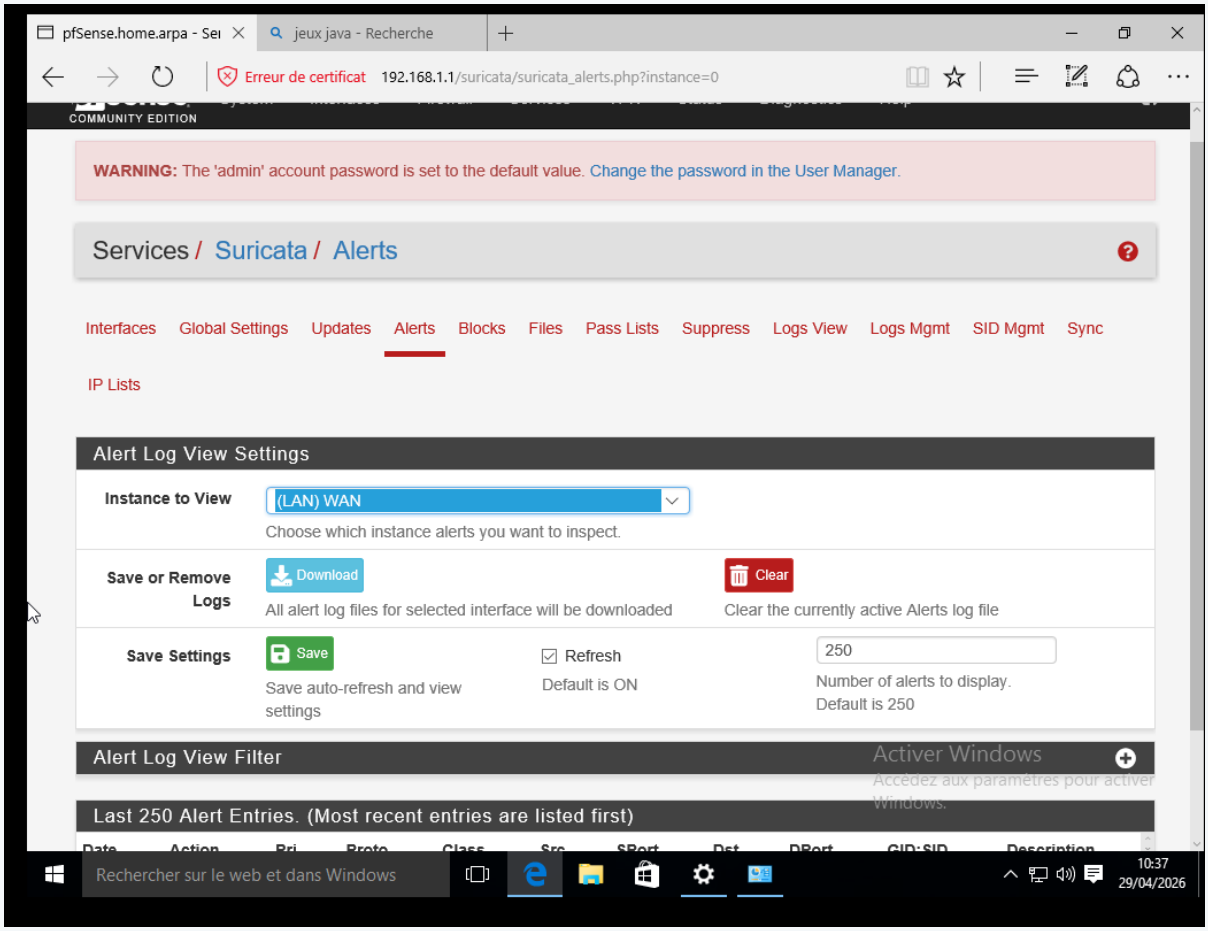
Session Actions Éditer Vue Aide

```
┌──(ntoguem㉿kali)-[~]
└─$ ping 192.168.1.20
PING 192.168.1.20 (192.168.1.20) 56(84) bytes of data.
64 bytes from 192.168.1.20: icmp_seq=1 ttl=128 time=1.32 ms
64 bytes from 192.168.1.20: icmp_seq=2 ttl=128 time=2.02 ms
64 bytes from 192.168.1.20: icmp_seq=3 ttl=128 time=1.15 ms
^C
--- 192.168.1.20 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2005ms
rtt min/avg/max/mdev = 1.149/1.495/2.022/0.378 ms

┌──(ntoguem㉿kali)-[~]
└─$ nmap -sS 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 11:04 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.10
Host is up (0.0013s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
MAC Address: 00:0C:29:B8:1D:0E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.15 seconds

┌──(ntoguem㉿kali)-[~]
└─$
```



3.2. Simulation d'exploitation (Metasploit)

Une tentative d'exploitation plus complexe via *msfconsole* a été réalisée. Suricata a généré des alertes plus critiques, prouvant sa capacité à détecter des signatures d'exploitation spécifiques.

```
ntoguem@kali: ~
Session  Actions  Éditer  Vue  Aide
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion        ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can o
pen an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.1.20
RHOSTS => 192.168.1.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass Password123!
SMBPass => Password123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.1.20:445      - 192.168.1.20:445      - Starting SMB login brutef
orce
[+] 192.168.1.20:445      - 192.168.1.20:445      - Success: '.\testuser:Pass
word123!'
[!] 192.168.1.20:445      - No active DB -- Credential data will not be saved
!
[*] 192.168.1.20:445      - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.1.20:445      - Bruteforce completed, 1 credential was successful
.
[*] 192.168.1.20:445      - You can open an SMB session with these credential
s and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

4. Analyse Technique

4.1. Mécanisme de détection

Suricata utilise l'**inspection profonde de paquets (DPI)**. Contrairement au pare-feu qui vérifie uniquement la source, la destination et le port, Suricata ouvre le paquet pour analyser son contenu et le comparer à sa base de données de signatures.

4.2. IDS vs IPS

Mode	Fonctionnement	Impact sur le trafic
IDS (Détection)	Surveille et alerte l'administrateur.	Laisse passer le trafic (passif).
IPS (Prévention)	Détecte, alerte et **bloque** l'attaquant.	Interrompt la connexion (actif).

4.3. Intérêt des signatures

Les signatures sont des "empreintes" numériques. Elles permettent une reconnaissance rapide et précise sans nécessiter une analyse comportementale complexe qui pourrait générer de nombreux faux positifs.

5. Options Avancées

- **Niveaux de sévérité :** Permet de prioriser les alertes (1: Critique, 2: Suspect, etc.) pour aider l'analyste SOC à se concentrer sur l'essentiel.
- **Filtrage des alertes :** Possibilité de supprimer les alertes redondantes ou d'ignorer certains faux positifs connus.
- **Mode Inline (IPS) :** En activant *Block Offenders*, Suricata devient une barrière active capable de couper la route à l'IP source de l'attaque.

6. Conclusion

La mise en place de Suricata transforme une architecture réseau "aveugle" en un système de défense proactif. En combinant le filtrage du pare-feu et l'analyse de l'IDS/IPS, nous obtenons une visibilité complète sur la sécurité du réseau, essentielle pour les centres d'opérations de sécurité (SOC) modernes.